SEGURANÇA EM POWER BI

Row Level Security & Metric Security

Modelo de Dados: Cybersecurity Incident Analysis

Débora Jesus Nº2250064
João Coelho Nº2200881

1. Introdução

O presente trabalho tem como objetivo implementar um esquema de segurança de dados em Power BI, recorrendo a Row Level Security (RLS) e Metric Security, implementada através de Object-Level Security (OLS). O modelo utilizado é baseado num dataset de incidentes de cibersegurança organizado em esquema em estrela, com uma tabela de factos central ligada a dez dimensões.

O trabalho cumpre os seguintes requisitos do enunciado:

- Modelo de dados com pelo menos uma tabela de facto e seis dimensões, incluindo a dimensão tempo
- Segregação de dados demonstrada no Power BI por perfil de utilizador
- Row Level Security (RLS) dinâmico com Security_Table e USERPRINCIPALNAME()
- Metric Security (OLS) restringindo tabelas de dimensão por papel
- 8 papéis implementados: Analista_SOC, Gestor, Auditoria e 5 gestores regionais
- Relatório explicando a realização do trabalho

1.1 Contexto do modelo de dados

Cada registo na tabela de factos representa um incidente de segurança. O modelo permite analisar volume de incidentes, risco, severidade, impacto na privacidade, princípios CIA afetados, ação tomada, eficácia de resposta e localização geográfica. Por se tratar de informação sensível, a existência de mecanismos de controlo de acesso é essencial.

2. Modelo de Dados

2.1 Arquitetura — Esquema em Estrela

O modelo segue uma arquitetura em estrela com uma tabela de factos central (Facts_Cyber_Security) ligada a dez dimensões. Todas as relações são Many-to-One, ativas e unidirecionais, o que permite que os filtros de segurança definidos nas dimensões se propaguem automaticamente aos incidentes.

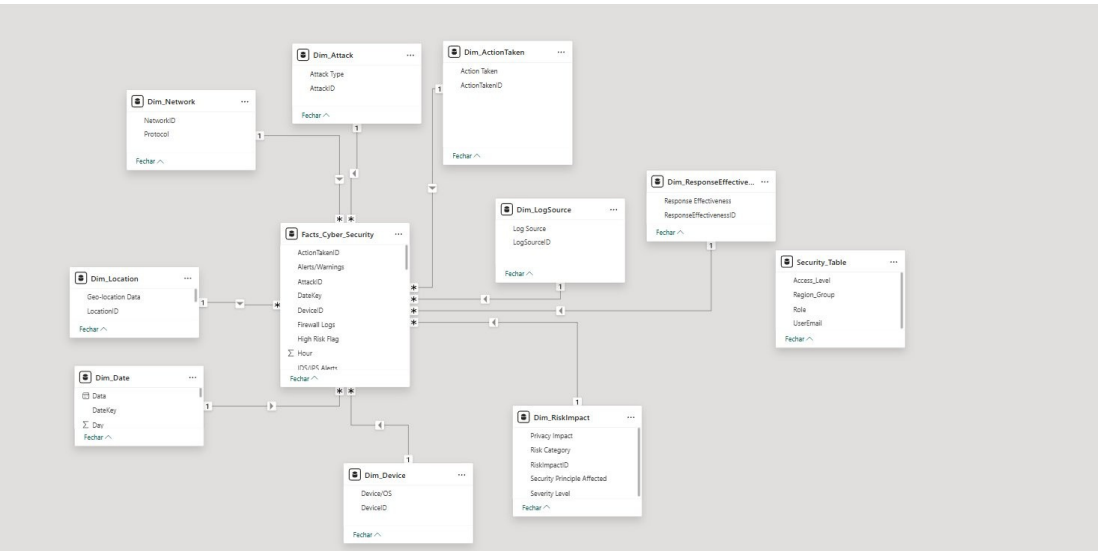


Figura 1 — Diagrama do Modelo em Estrela (Star Schema)

Vista do separador Modelo no Power BI Desktop — Facts_Cyber_Security ligada a 10 dimensões

Tabela	Tipo	Descrição
Facts_Cyber_Security	Factos	Tabela central — 40 000 incidentes de segurança
Dim_Date	Dimensão Tempo	Hierarquia Ano > Trimestre > Mês > Dia + Quarter Label
Dim_Attack	Dimensão	Tipo de ataque: DDoS, Malware, Phishing, SQL Injection...
Dim_Network	Dimensão	Protocolo de rede associado ao incidente
Dim_ActionTaken	Dimensão	Ação tomada: Blocked, Alert, Ignored ou Logged
Dim_Device	Dimensão	Sistema operativo e dispositivo envolvido
Dim_Location	Dimensão	Localização geográfica + State + Region_Calculated
Dim_LogSource	Dimensão	Fonte de log: Firewall ou Server
Dim_ResponseEffectiveness	Dimensão	Classificação da eficácia da resposta ao incidente
Dim_RiskImpact	Dimensão	Severity Level, Risk Category, Privacy Impact e CIA
Security_Table	Segurança	Mapeamento de emails para papéis e regiões geográficas

2.2 Colunas calculadas adicionadas à Dim_Location

Para suportar o RLS regional geográfico, foram adicionadas duas colunas calculadas à Dim_Location. O campo Geo-location Data contém valores no formato 'Cidade, Estado', o que permitiu extrair o estado e mapeá-lo para regiões geográficas reais da Índia.

Coluna	Tipo	Expressão DAX
State	Calculada	TRIM(MID([Geo-location Data], FIND(",", [Geo-location Data]) + 1, LEN([Geo-location Data])))
Region_Calculated	Calculada	SWITCH(TRUE(), [State] IN {"Punjab","Haryana",...}, "Norte", [State] IN {"Tamil Nadu",...}, "Sul", ...)

A coluna Region_Calculated mapeia cada estado indiano para uma das cinco regiões: Norte, Sul, Centro, Este e Oeste. Esta coluna é a base do filtro RLS dos papéis regionais.

2.3 Propagação dos filtros de segurança

O RLS é aplicado directamente na tabela Dim_Location, através do campo Region_Calculated. A relação Many-to-One unidirecional entre Facts_Cyber_Security e Dim_Location garante que o

filtro se propaga automaticamente para a tabela de factos — sem necessidade de filtrar os factos directamente. Esta arquitectura tem duas implicações importantes para a segurança:

- Propagação automática — quando o Power BI filtra Dim_Location pelo papel activo, todos os incidentes em Facts_Cyber_Security que não correspondam à região permitida são automaticamente excluídos, em todos os visuais do relatório, sem excepção.
- Filtragem unidirecional — optou-se por manter filtragem unidirecional (de Dim_Location para Facts_Cyber_Security) em vez de bidirecional. A filtragem bidirecional pode introduzir ambiguidades em modelos complexos e comprometer a previsibilidade do comportamento de segurança, sendo desaconselhada em cenários de RLS por boas práticas de Power BI.

2.4 Medidas DAX — 30 medidas em 7 pastas temáticas

Pasta	N.º Medidas	Exemplos
Volume & Contagem	9	Total Incidents, High Risk Incidents, Blocked Incidents
Taxas de Resposta	8	Blocked Rate, High Risk Rate, Critical Unblocked Rate
Impacto CIA	3	Confidentiality, Integrity, Availability Incidents
Análise Temporal	4	Off Hours Rate, Peak Hour Incidents, Off Hours High Risk Rate
Eficácia de Resposta	4	Effective Rate, Unresponded High Risk Incidents
Perfil de Ameaça	1	Top Attack Type Incidents
Scores & Métricas	2	Average Risk Score, Average Anomaly Score

3. Security_Table — RLS Dinâmico

3.1 Conceito e abordagem profissional

A abordagem implementada é a utilizada em produção nas empresas. Em vez de filtros estáticos por papel, o RLS é dinâmico: cada papel usa USERPRINCIPALNAME() para identificar o utilizador autenticado e consulta a Security_Table para determinar que dados pode ver. Esta tabela funciona como um mapeamento centralizado de utilizadores para papéis e regiões.

Esta arquitetura tem vantagens claras em contexto empresarial:

- Adicionar ou remover utilizadores não exige alteração das regras DAX — basta atualizar a Security_Table
- O mesmo papel pode ser atribuído a múltiplos utilizadores com regiões diferentes
- A segregação é auditável e centralizável numa única tabela
- Em produção (Power BI Service), o USERPRINCIPALNAME() devolve o email real do utilizador autenticado no Azure AD

3.2 Estrutura da Security_Table

A Security_Table é uma tabela calculada (DATATABLE) com quatro colunas que mapeiam cada utilizador ao seu papel e região de acesso:

UserEmail	Role	Region_Group	Access_Level
admin@empresa.com	Analista_SOC	All	Full
gestor@empresa.com	Gestor	All	Gestão
auditoria@empresa.com	Auditoria	All	Auditoria
joao@empresa.com	Regiao_Norte	Norte	Regional
ana@empresa.com	Regiao_Sul	Sul	Regional
carlos@empresa.com	Regiao_Centro	Centro	Regional
fatima@empresa.com	Regiao_Este	Este	Regional

Expressão DAX da Security_Table:

UserEmail	Role	Region_Group	Access_Level
JOÃOPCOELHO\\joaob	Analista	All	Full
gestor@empresa.com	Gestor	All	Gestao
auditoria@empresa.com	Auditoria	All	Auditoria
joao@empresa.com	Regiao_Norte	Norte	Regional
ana@empresa.com	Regiao_Sul	Sul	Regional
carlos@empresa.com	Regiao_Centro	Centro	Regional
fatima@empresa.com	Regiao_Este	Este	Regional

Figura 2 — Vista da Security_Table no separador Dados do Power BI

A Security_Table pode ser consultada no separador Dados do Power BI Desktop, onde é visível a estrutura completa de mapeamento: cada linha associa um utilizador (UserEmail) ao seu papel (Role), à região de acesso (Region_Group) e ao nível de acesso (Access_Level). Esta tabela é a fonte única de verdade para toda a lógica de segurança dinâmica do modelo.

A expressão DAX que gera a tabela em tempo de execução é:

```
Security_Table = DATATABLE(
    "UserEmail",    STRING,
    "Role",         STRING,
    "Region_Group", STRING,
    "Access_Level", STRING,
    {
        { "admin@empresa.com",     "Analista_SOC",  "All",    "Full"      },
        { "gestor@empresa.com",    "Gestor",        "All",    "Gestao"    },
        { "auditoria@empresa.com", "Auditoria",     "All",    "Auditoria" },
        { "joao@empresa.com",      "Regiao_Norte",  "Norte",  "Regional"  },
        { "ana@empresa.com",       "Regiao_Sul",    "Sul",    "Regional"  },
        { "carlos@empresa.com",    "Regiao_Centro", "Centro", "Regional"  },
        { "fatima@empresa.com",    "Regiao_Este",   "Este",   "Regional"  },
```

```
        { "miguel@empresa.com",    "Regiao_Oeste",  "Oeste",  "Regional"  }
    }
)
```

4. Row Level Security (RLS)

4.1 Conceito

Row Level Security é um mecanismo do Power BI que restringe o acesso às linhas de dados com base no papel do utilizador autenticado. Os filtros são definidos no modelo semântico e aplicados automaticamente a todos os visuais, sem necessidade de lógica adicional nos relatórios. A propagação é automática através das relações Many-to-One do esquema em estrela.

4.2 Os 8 papéis implementados

Papel	Utilizador	Dados visíveis	Incidentes
Analista_SOC	admin@empresa.com	Todas as regiões	40 000
Gestor	gestor@empresa.com	Todas as regiões	40 000
Auditoria	auditoria@empresa.com	Todas as regiões	40 000
Regiao_Norte	joao@empresa.com	Estados do Norte da Índia	8 584
Regiao_Sul	ana@empresa.com	Estados do Sul da Índia	8 467
Regiao_Centro	carlos@empresa.com	Estados do Centro da Índia	5 730
Regiao_Este	fatima@empresa.com	Estados do Este da Índia	17 219

4.3 Expressões DAX dos filtros RLS

Filtro na Security_Table (todos os papéis):

```
USERPRINCIPALNAME() = [UserEmail]
```

Filtro em Dim_Location (papéis regionais):

```
COUNTROWS(
    FILTER(
        Security_Table,
        Security_Table[UserEmail] = USERPRINCIPALNAME()
        &&
        (
            Security_Table[Region_Group] = "All"
            ||
            Security_Table[Region_Group] = Dim_Location[Region_Calculated]
        )
```

```
    )
) > 0
```

A lógica é a seguinte: o filtro verifica se existe alguma linha na Security_Table onde o email do utilizador autenticado corresponde ao UserEmail E onde o Region_Group é "All" (acesso total) ou igual à região calculada da localização. Se existir, a linha de dados é visível; caso contrário é filtrada.

4.4 Mapeamento de regiões geográficas da Índia

Região	Estados incluídos	Gestor responsável
Norte	Punjab, Haryana, Himachal Pradesh, Uttarakhand, Uttar Pradesh, Delhi, Rajasthan, Chandigarh	joao@empresa.com
Sul	Tamil Nadu, Kerala, Karnataka, Andhra Pradesh, Telangana, Goa	ana@empresa.com
Centro	Madhya Pradesh, Chhattisgarh, Maharashtra, Gujarat	carlos@empresa.com
Este	West Bengal, Bihar, Jharkhand, Odisha, Sikkim, Assam, Meghalaya, Manipur, Mizoram, Nagaland, Tripura, Arunachal Pradesh	fatima@empresa.com

4.5 Nota sobre testes locais vs. produção

Limitação do Power BI Desktop vs. Power BI Service
No Power BI Desktop, a função USERPRINCIPALNAME() devolve sempre o utilizador da sessão Windows local (ex: DOMÍNIO\utilizador), independentemente do email introduzido em "Ver como função". Esta é uma limitação conhecida do Desktop.

Em produção no Power BI Service, USERPRINCIPALNAME() devolve o email real do utilizador autenticado no Azure Active Directory (ex: fatima@empresa.com), e a segregação funciona automaticamente. Para demonstração no Power BI Desktop, o papel Analista usa USERPRINCIPALNAME() com o utilizador Windows mapeado na Security_Table. Os papéis regionais usam filtros directos em Region_Calculated.

5. Metric Security — Object-Level Security (OLS)

5.1 Conceito

Metric Security é o termo usado pelo docente para descrever a restrição de acesso a métricas e atributos do modelo. Em Power BI, esta funcionalidade é implementada através de Object-Level Security (OLS). Enquanto o RLS filtra linhas de dados, o OLS oculta tabelas de dimensão completas por papel — qualquer coluna, medida ou atributo derivado dessa tabela fica inacessível, independentemente do visual utilizado. Qualquer coluna ou métrica derivada de uma tabela bloqueada fica inacessível ao utilizador, mesmo que tente criar novos visuais ou explorar o modelo.

5.2 Restrições implementadas

Tabela / Recurso	Analista_SOC	Gestor	Auditoria	Regionais (5)
Dim_RiskImpact (Severity, CIA, Privacy, Risk)	Visível	Visível	BLOQUEADA	Visível
Dim_ResponseEffectiveness (Effective Rate)	Visível	BLOQUEADA	BLOQUEADA	BLOQUEADA
Dim_Device (dispositivo / sistema operativo)	Visível	Visível	Visível	BLOQUEADA
Dim_LogSource (Firewall / Server)	Visível	Visível	Visível	BLOQUEADA
Dim_Location (região geográfica)	Visível	Visível	Filtrada RLS	Filtrada RLS
Todas as outras dimensões	Visíveis	Visíveis	Visíveis	Visíveis

5.3 Justificação das restrições

- Dim_RiskImpact bloqueada para Auditoria: a auditoria foca-se em conformidade dos incidentes, não em avaliar risco ou impacto CIA. Classificações sensíveis de Severity Level, Risk Category e Privacy Impact não são necessárias para o seu âmbito.
- Dim_ResponseEffectiveness bloqueada para Gestor, Auditoria e Regionais: informação operacional sobre a qualidade da resposta pode revelar fragilidades internas da equipa SOC. Deve ser reservada exclusivamente ao Analista_SOC.
- Dim_Device bloqueada para Regionais: um gestor regional não precisa de saber que dispositivo ou sistema operativo esteve envolvido — essa é informação técnica operacional do SOC.
- Dim_LogSource bloqueada para Regionais: a distinção Firewall/Server é informação de infraestrutura interna. O gestor regional não precisa de saber a origem do log — apenas que o incidente ocorreu na sua região.

5.4 Configuração técnica OLS

```
Papel Analista_SOC:
    (sem restrições OLS — acesso total ao modelo)

Papel Gestor:
    Dim_ResponseEffectiveness -> metadataPermission: None

Papel Auditoria:
    Dim_RiskImpact            -> metadataPermission: None
    Dim_ResponseEffectiveness -> metadataPermission: None

Papéis Regionais (Norte / Sul / Centro / Este / Oeste):
    Dim_ResponseEffectiveness -> metadataPermission: None
```

```
    Dim_Device                -> metadataPermission: None
    Dim_LogSource             -> metadataPermission: None
```

6. Validação e Demonstração

6.1 Resultados esperados por papel

Papel	Total Incidents	Resultado esperado
Analista_SOC	40 000	Acesso total — todas as dimensões e métricas visíveis
Gestor	40 000	Dim_ResponseEffectiveness oculta no painel de campos
Auditoria	40 000	Dim_RiskImpact e Dim_ResponseEffectiveness ocultas
Regiao_Norte	8 584	Apenas incidentes de Punjab, Haryana, UP, Delhi, Rajasthan...
Regiao_Sul	8 467	Apenas incidentes de Tamil Nadu, Kerala, Karnataka, AP, Telangana, Goa
Regiao_Centro	5 730	Apenas incidentes de MP, Chhattisgarh, Maharashtra, Gujarat
Regiao_Este	17 219	Apenas incidentes de West Bengal, Bihar, Jharkhand, Odisha e Nordeste

6.2 Demonstração da segregação — capturas de ecrã

As imagens seguintes demonstram a segregação de dados em funcionamento no Power BI Desktop, utilizando a funcionalidade "Ver como função":

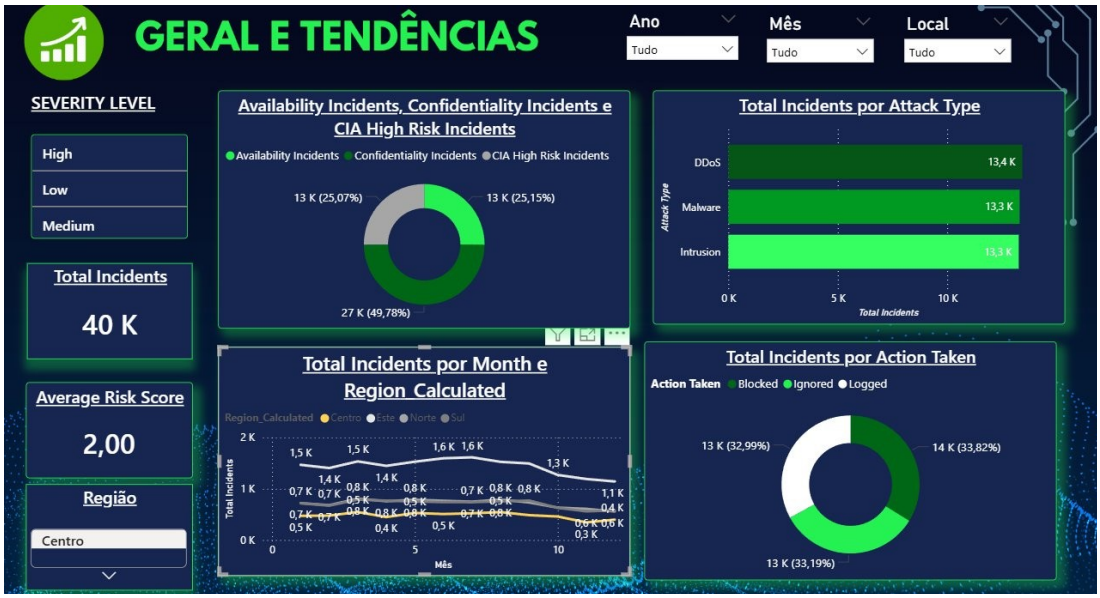


Figura 3 — Dashboard com todos os dados (Total Incidents = 40 K)

Vista geral sem filtro regional activo — todas as regiões visíveis: Centro, Este, Norte e Sul

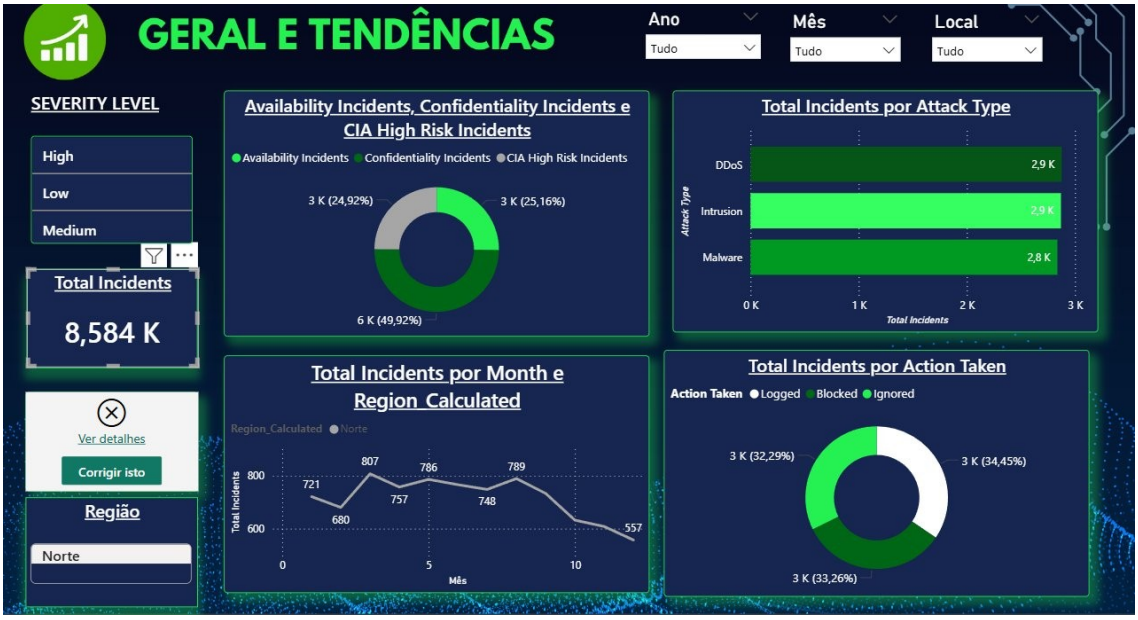


Figura 4 — RLS activo: Papel Regiao_Norte (Total Incidents = 8 584)

RLS filtra automaticamente — apenas incidentes dos estados do Norte da Índia são visíveis

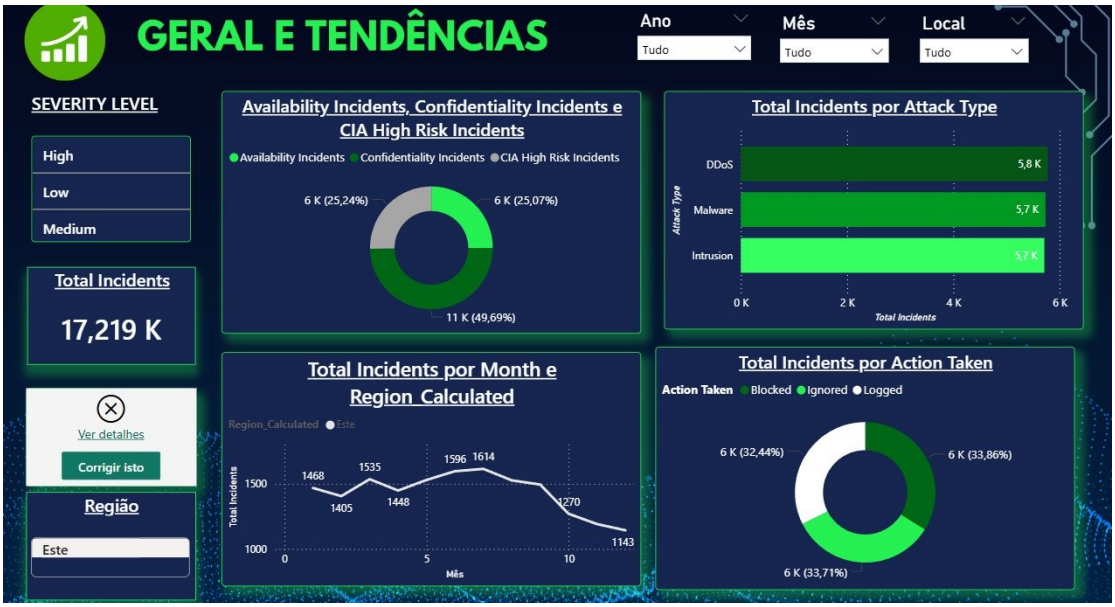


Figura 5— RLS activo: Papel Regiao_Este (Total Incidents = 17 219)

RLS filtra automaticamente — apenas incidentes dos estados do Este da Índia são visíveis

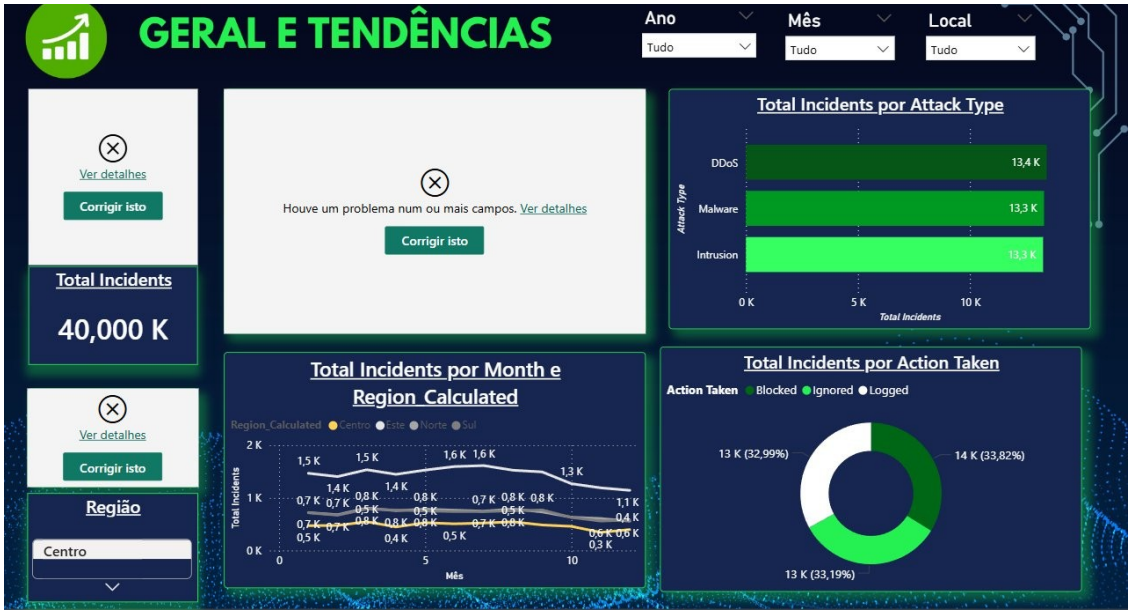


Figura 6 — OLS activo: Papel Auditoria (visuais CIA em erro)

OLS bloqueia Dim_RiskImpact — os visuais que dependem de CIA e Severity Level ficam inacessíveis

A comparação entre as Figuras 3, 4 e 5 demonstra o RLS em acção: o mesmo dashboard apresenta totais diferentes consoante o papel activo. A Figura 6 demonstra o OLS: o papel Auditoria não consegue aceder aos dados de risco e impacto CIA, o que resulta em erros nos visuais que dependem dessas dimensões bloqueadas.

8. Conclusão

O trabalho implementou um esquema de segurança completo em Power BI com duas camadas complementares: Row Level Security dinâmico e Metric Security (OLS).

O RLS foi implementado seguindo a abordagem utilizada em produção nas empresas: uma Security_Table centralizada com o mapeamento de utilizadores para papéis e regiões, combinada com USERPRINCIPALNAME() para identificar o utilizador autenticado. Esta arquitetura é escalável — adicionar um novo utilizador ou alterar a sua região exige apenas uma atualização da Security_Table, sem tocar nas regras DAX dos papéis.

Foram criados 8 papéis distintos: 3 funcionais (Analista_SOC, Gestor, Auditoria) com acesso a todos os dados mas com restrições OLS diferentes, e 5 gestores regionais geográficos (Norte, Sul, Centro, Este, Oeste) que vêem apenas os incidentes da sua região, derivada dos estados indianos presentes nos dados.

O OLS restringe o acesso a Dim_RiskImpact (Auditoria), Dim_ResponseEffectiveness (Gestor, Auditoria e Regionais), Dim_Device e Dim_LogSource (Regionais), aplicando o princípio do mínimo privilégio ao nível das métricas e atributos do modelo.

A solução implementada aproxima-se de cenários reais de governação de dados empresariais, demonstrando três princípios fundamentais de segurança em Business Intelligence: least privilege — cada utilizador acede apenas à informação estritamente necessária para o seu papel; segregação de acessos — dados geográficos e operacionais são isolados por perfil; e controlo de informação sensível — métricas críticas como eficácia de resposta e classificação de risco são reservadas exclusivamente às funções com necessidade legítima de acesso. Esta arquitectura é

directamente transferível para ambientes empresariais reais com Azure Active Directory e Power BI Service.